Bonusaufgabe: SQL-Injection

Hinweis: Das Forum dieser Aufgabe nutzt eine MySQL Datenbank. Der relevante Unterschied ist, dass in MySQL sowohl Anführungzeichen (`"`) als auch Hochkommata (`'`) einen String markieren können. Bezeichner werden mit Backticks (`` ` ``) markiert. In Postgres werden Strings nur mit Hochkommata (`'`) und Bezeichner mit Anführungszeichen (`"`) markiert.

SQL-Injection (1 Bonuspunkt)

Für diese Aufgabe wird Ihnen ein gefaktes Forum https://fk-feedback-test.mni.thm.de:4082/forum/ bereitgestellt. Geben Sie hier keine sensiblen Daten ein – diese sind nicht sicher. Ein Registrieren im Forum ist nicht nötig.

Untersuchen Sie die verschiedenen Eingabe-Felder in diesem Forum, ob hier SQL Injections möglich sind und welche Arten von Anführungszeichen im dazugehörigen Query verwendet werden. Lesen Sie aus den privaten Messages den Message-Text aus, der als Message-Subjekt die ersten 4 Buchstaben/Zahlen Ihrer CAS-Kennung hat. Spielen Sie die Lösung in das Ihnen bekannte Feedbacksystem ein.

Wichtig:

Um Zugriff auf das BB-Forum zu erhalten, welches SQL-Injections ermöglicht, müssen Sie sich zunächst im **VPN-Netz** der THM verbinden. Danach müssen Sie noch Ihre eigene IP-Adresse per CAS-Authentifizierung freischalten. Hierzu reicht ein Aufruf der Seite https://fk-feedback-test.mni.thm.de/sqli-unlock/. (**Falls der Link nicht funktioniert** prüfen Sie im Browser, ob der Link mit dem in diesem Dokument übereinstimmt, insbesondere auf das `-` zwischen `fk` und `feedback` in der URL. Manche PDF-Viewern entfernen dies).

Danach können Sie auf https://fk-feedback-test.mni.thm.de:4082/forum/ zugreifen. Sie dürfen in das Forum händische Eingaben tätigen, die eine SQL-Injection auslösen, um so Daten auszulesen. Andere SQL-Injections oder die Verwendung von automatischen Tools sind verboten und werden als unerlaubten Hackerangriff verfolgt und geahndet (u.a. Datenschutzgesetz §52: Strafe bis 18.890 Euro).